#A A refresh token.

When the access token expires, the client can then use the refresh token to obtain a fresh access token from the AS without the resource owner needing to approve the request again. Because the refresh token is only sent over a secure channel between the client and the AS, it's considered more secure than an access token that might be sent to many different APIs.

> **DEFINITION** A client can use a ***refresh token*** to obtain a fresh access token when the original one expires. This allows an AS to issue short-lived access tokens without clients having to ask the user for a new token every time it expires.

By issuing a refresh token, the AS can limit the lifetime of access tokens. This has a minor security benefit because if an access token is stolen, then it can only be used for a short period of time. But in practice, a lot of damage could be done even in a short space of time by an automated attack, such as the Facebook attack discussed in chapter 6 (https://newsroom.fb.com/news/2018/09/security-update/). The primary benefit of refresh tokens is to allow the use of stateless access tokens such as JWTs. If the access token is short-lived, then the client is forced to periodically refresh the token at the AS, providing an opportunity for the token to be revoked without the AS maintaining a large blacklist. The complexity of revocation is effectively pushed to the client, which must now handle periodically refreshing its access tokens.